SECURITY

Threat Modeling Visual Guide

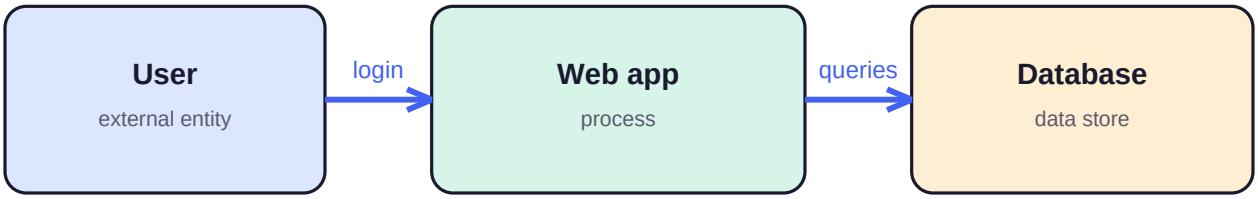
Design-time security —
find the flaws before the code exists.

ANIMATED WALKTHROUGH
Step through pages to play the animation

STEP 1/6

Start with a Data-Flow Diagram

You can't threaten what you haven't drawn.

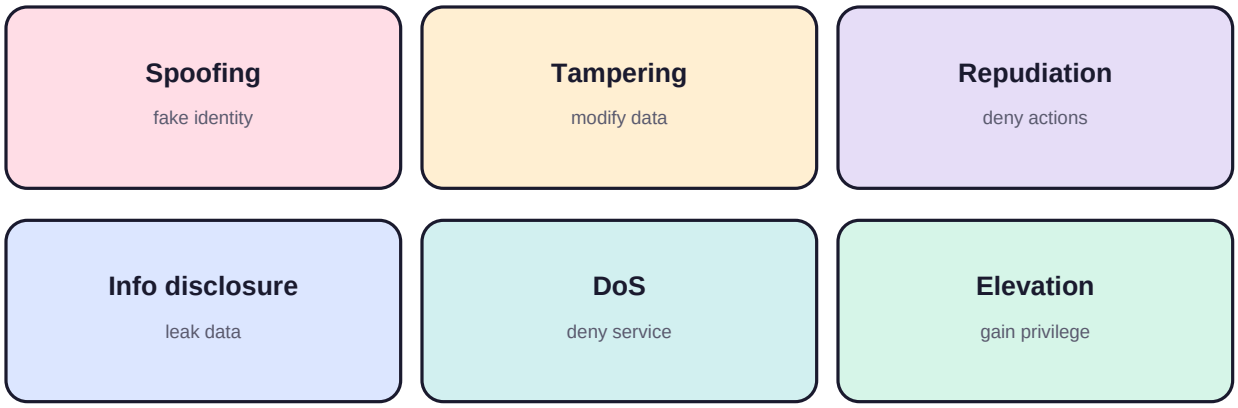


Mark trust boundaries (browser→app, app→DB) — every crossing is where threats live. Keep the diagram honest and current.

STEP 2/6

STRIDE: The Six Threat Buckets

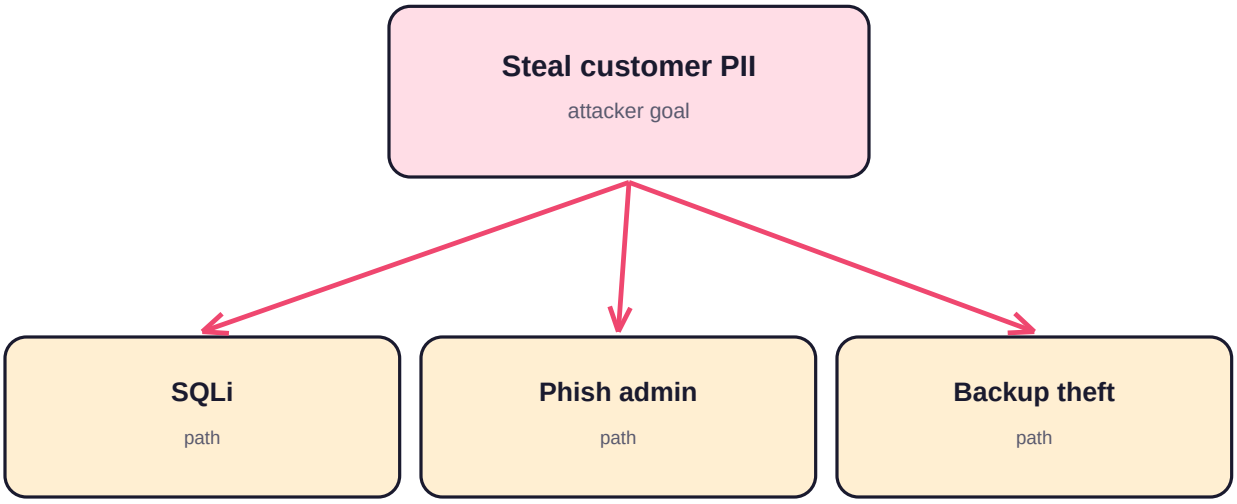
Walk every DFD element through all six.



STEP 3/6

Attack Trees

One goal, many paths — drawn as a tree.



Prune any path your controls already kill. What remains is your real residual risk — and your fix list.

STEP 4/6

Prioritize: Risk = Impact × Likelihood

Not every threat deserves a sprint.

High impact

Fix now: PII theft, auth bypass, RCE on crown jewels.

Lower risk

Backlog with owners: harden opportunistically.

Score simply (1–3 × 1–3) and move on — precision theater wastes the workshop. Revisit when the design changes.

STEP 5/6

When to Threat Model

At design time — and at every inflection point.

- New features and architectures: model before the first line of code.
- Major changes: new data flows, new trust boundaries, new third parties.
- Lightweight for small changes (30-min whiteboard), deep for crown jewels.
- Make it a gate: no design review sign-off without the threat model.

STEP 6/6

Outputs That Survive

A threat model is a living document, not a meeting.

- Threat list: each with STRIDE category, affected flow, risk score, owner.
- Mitigations as tickets — linked, scheduled, and verified when done.
- Assumptions recorded explicitly (they're the threats you chose to accept).
- Review trigger: architecture change or calendar date, whichever comes first.

STEP ✓I✓

Key Takeaways

Threat Modeling — Remember

- Draw the data-flow diagram first; threats live at trust boundaries.
- Run every element through STRIDE: spoofing, tampering, repudiation, disclosure, DoS, elevation.
- Attack trees turn one goal into prunable paths — fix what remains.
- Prioritize by impact × likelihood; keep scoring simple and fast.
- Model at design time and at every architecture inflection.
- Output tickets with owners, record assumptions, and re-review on change.

Keep exploring

Pair this guide with the matching video walkthroughs and hands-on labs at interstitiumlabs.dev